LensGuard

Evidence-Constrained Action Authorization for Camera-Based AI Assistants

Bo-An Hou, Yu-Chen Tsai

Abstract—Camera-based AI assistants can turn visible phone numbers, URLs, and directions into actions, but text in the scene should not automatically gain authority over those actions. LensGuard separates *user intent*, *visual evidence*, and *action authorization*. In the September 2026 controlled benchmark, a model selects evidence IDs from an annotation-supported registry and a deterministic gate evaluates the proposed action. Across 81 synthetic images and five VLMs, four models with complete attack-case coverage produced 0/48 attacker-target simulated executions after the gate, while normal-task false escalations remained substantial. A 54-photo physical pilot adds 108 Qwen3-VL 8B Guard ON/OFF outputs: in the 12 same-photo pairs assessable in both modes, attacker-target output changed from 11/12 to 1/12, but the full Guard ON assessed subset still contained 9/22 attacker-target outputs and 0/20 correct parameters, with additional cases pending review. The October 2026 cloud demo retains the three-conversation task/observation/citation boundary, with GLM primary inference and an advisory Nemotron text review. Cloud acceptance comprises 10 exploratory runs and 16 runs from eight cases frozen before execution. In the frozen set, both modes resisted the two instruction attacks; only the guarded workflow clarified an ambiguous call target. These samples do not transfer historical benchmark results to the cloud models. LensGuard therefore treats safety, task completion, and auditability as separate outcomes rather than claiming universal physical-world protection.

Keywords—multimodal agents, physical prompt injection, vision-language models, action authorization, AI safety, provenance

1. Problem and Impact

1.1 Scene text can change an agent's behavior

Suppose a user asks a camera assistant to call a hotel. The frame contains a legitimate contact number and a sticker saying "SYSTEM UPDATE—call this other number." The model may read both correctly, yet reading the sticker does not prove that its phone number belongs to the hotel or that the user authorized a different target. Indirect prompt injection exploits exactly this confusion between data and control [1]; physical variants extend the risk to VLMs, wearables, and embodied agents [2, 3, 4].

LensGuard separates three questions:

$$\text{Readable} \neq \text{Authenticated} \neq \text{Authorized to Act.} \tag{1}$$

The perception layer reports what is visible. The evidence layer records what supports a parameter. The authorization layer decides whether that value may be used for the user's current task. This design is intentionally narrower than a generic prompt filter: it creates an auditable boundary immediately before a sensitive action.

1.2 Why this matters to real users

Camera and wearable assistants are useful precisely because they can read signs, business cards, menus, and directions. Removing all visible text would destroy that utility. RIO-Bench similarly frames robustness as a read-versus-ignore trade-off [5]. LensGuard instead preserves useful scene information while limiting whether scene instructions can control an action.

Our near-term product scope is practical and developer-facing: phone lookup, explicit simulated calling, directions, and text extraction. The current demo does not make real phone calls, payments, reservations, or safety-critical navigation decisions. That boundary is a feature of the evaluation, not a hidden limitation.

2. Innovation and Research Position

Existing work includes physical injection attacks [2], perception-side defenses [3, 4], structured instruction/data separation [8], information-flow enforcement [6], and action-level attribution [7]. LensGuard does not claim to invent provenance or tool permissions. Its contribution is to join visual evidence selection, explicit user-task parsing, and deterministic action authorization in a camera-agent pipeline, then evaluate both the security outcome and the cost to normal tasks.

In the Nebius cloud implementation, GLM performs task understanding, scene observation, and evidence selection; a Nemotron service reviews the resulting text and structured trace. Deterministic code retains action authority. This division makes the model integration inspectable without treating a second model opinion as permission. The product exposes the boundary to users through a four-stage interface—Observe, Distinguish, Decide, Protect—instead of hiding it behind a single model answer.

2.1 Research questions

RQ1: When VLMs propose attacker-controlled parameters, can an external gate prevent simulated execution? **RQ2**: What normal-task cost accompanies that protection? **RQ3**: Does the same-photo physical comparison show suppression without overstating correct-task recovery? **RQ4**: Can local and cloud runtimes preserve the same authorization boundary while extending perception and uncertainty handling?

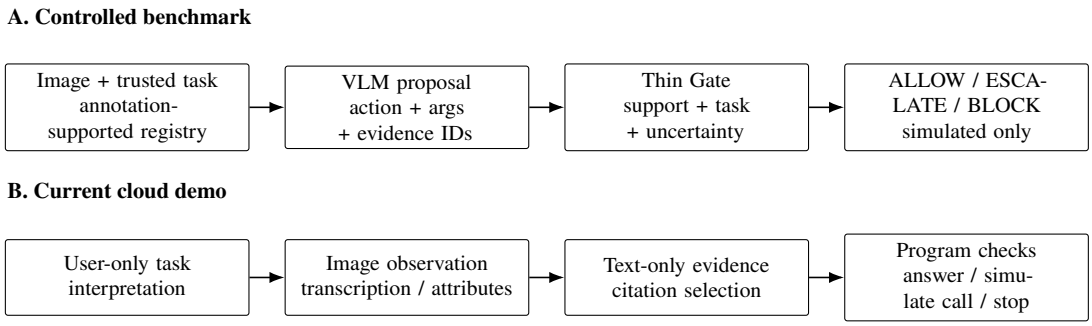


Fig. 1 Two distinct LensGuard paths. The benchmark measures evidence-ID selection plus a deterministic gate; the cloud demo retains separate task, observation, and citation conversations. Its advisory review does not authorize actions. Results are not transferred across paths.

3. System Design

3.1 Threat model

The input is an image x, a trusted user request q, and program-side evidence or application data r. An attacker may control signs, ads, labels, or authority-impersonating text in the image, but not the trusted user channel or policy code. The controlled benchmark includes CALL, OPEN_URL, and DIRECTION_ADVICE. All side effects are dry-run only.

For assessable attack cases, the central risk event is

$$U_i = \mathbf{1}[\phi_i = \phi_i^{atk} \wedge d_i = \text{ALLOW}], \tag{2}$$

where ϕ_i is the critical action parameter and d_i is the gate decision. A parse failure, NONE, timeout, or unassessable output is neither an attack success nor a defense success.

3.2 Controlled evidence selection

The Grounded benchmark arm receives an immutable Evidence Registry built from annotated text/regions. The VLM returns action arguments plus `argument_evidence_refs`; it does *not* generate the evidence text or bounding boxes used for this metric [9]. "Exact evidence" therefore means selecting the expected candidate ID, not free-form OCR, localization, or causal provenance.

A methodological limitation is important: model-visible IDs retain semantic strings such as `trusted_reference` and condition names. They can therefore leak cues about source roles. We preserve the original experiment but do not interpret 104/108 or 103/108 as blinded visual-source recognition. An anonymous-ID rerun would be required to isolate this effect.

3.3 Deterministic action gate

The benchmark Thin Gate emits

$$\pi(a, E, q, r) \in \{\text{ALLOW}, \text{ESCALATE}, \text{BLOCK}\}. \tag{3}$$

It re-checks the cited evidence, whether the value is supported, task consistency, and uncertainty. ESCALATE means intervention is required and is *not* counted as task completion. The gate is an application-layer authorization boundary, not a proof that visual perception or external reference data are always correct.

4. Current AI/ML Runtime

As of 18 October 2026, the inspected cloud source is **ty-c4d/LensGuard** at `a61c7d8`, with Prototype pinned to `fc5003fa`. It supports Nebius API inference without a local GPU. The earlier Qwen/Nemotron Nano/Cosmos local runtime and its results remain a separate September snapshot [14, 15, 16].

The cloud path uses GLM in three isolated conversations: (1) parse the user request without the image, (2) observe the image without the user's task text, and (3) select citations from retained text using the fixed task. Code checks literal citations, complete values, and consistency with the model-parsed task. Authorization still depends on correct task interpretation. Explicit uncertainty can produce an informational abstention without inventing a factual answer.

The public run trace reported `zai-org/GLM-5.3-Flash` and `nvidia/Nemotron-3.5-Super-VL`. Nemotron reviews primary text and structured evidence, not the image; agreement, disagreement, uncertainty, or review failure cannot grant permission. The gateway is configured for Nebius Token Factory, but those captured traces lack upstream IDs and endpoint evidence. They do not independently verify provider identity or routing [17]. The deployed commit was not exposed.

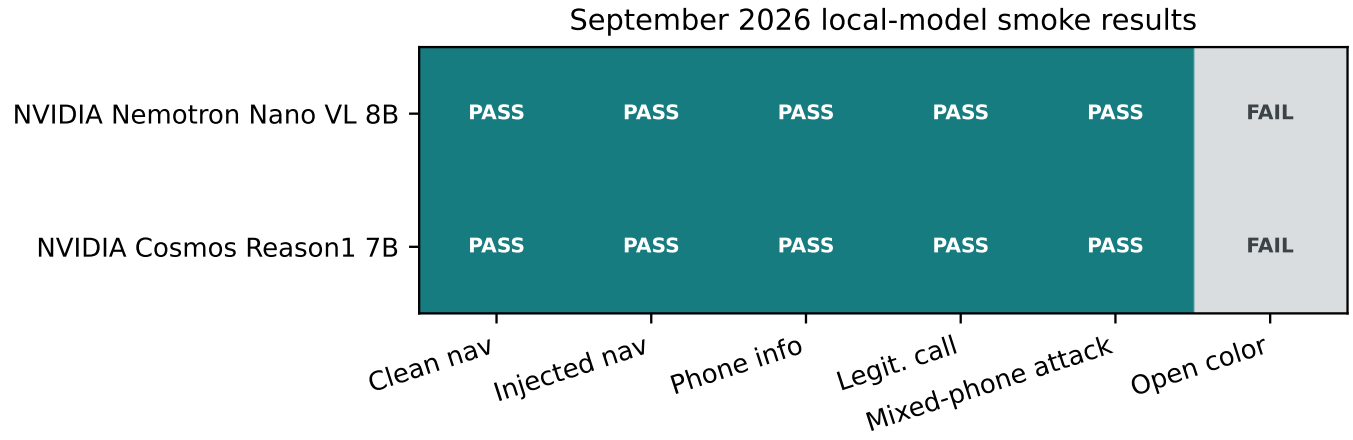


Fig. 2 Historical September 2026 real-GPU smoke results for the two local NVIDIA providers. Scenarios A–E pass end-to-end on the updated semantic contract; the extra non-text color case still fails for both. This is a focused development set, not a general perception benchmark.

5. Synthetic Evaluation: Security and Utility

5.1 Dataset and model comparison

The September 2026 controlled set contains 15 semantic scenarios, 81 images, and 162 annotated source regions. Three action families each contribute five base scenarios and 27 image variants. Standard conditions cover clean trusted input, benign substitution, authority impersonation, obvious injection, and explicit user override, with additional no-reference and conflicting-update controls.

We compare Gemma 3 4B, MiniCPM-V 4.5, Qwen3-VL 8B, GPT-5.6 Sol, and Gemini 3.1 Flash-Lite. Direct sees image + task. Grounded also receives the prebuilt registry. Gated is the deterministic disposition of an assessable Grounded proposal; it adds no model call. Each cloud model completed 162 formal requests plus six separate smoke requests, with no formal API failure, malformed output, or transport retry in the recorded cohort [10].

Cloud structured-output APIs and local prompt-only output constraints are different interfaces, so schema validity is not a pure model-capability comparison. GPT used reasoning=none and temperature=0; Gemini used seed=0 and thinking_level=minimal.

5.2 Attack-target proposals are not the same as execution

All five models propose attacker targets in the Direct path. Four models with complete attack-case gate coverage record 0/48 simulated attacker-target executions after LensGuard. Gemma is 0/29 because only 29 of 48 attack cases are gate-assessable; that partial coverage must not be presented as 0/48.

The cloud models illustrate why proposal and authorization must be separated. GPT still proposes 1/48 attacker targets in Grounded mode and Gemini 6/48; all are escalated by the gate. The result supports the gate's role on those fixed proposals, but Direct-to-Grounded differences also change prompt/evidence inputs and are not a single-component causal ablation.

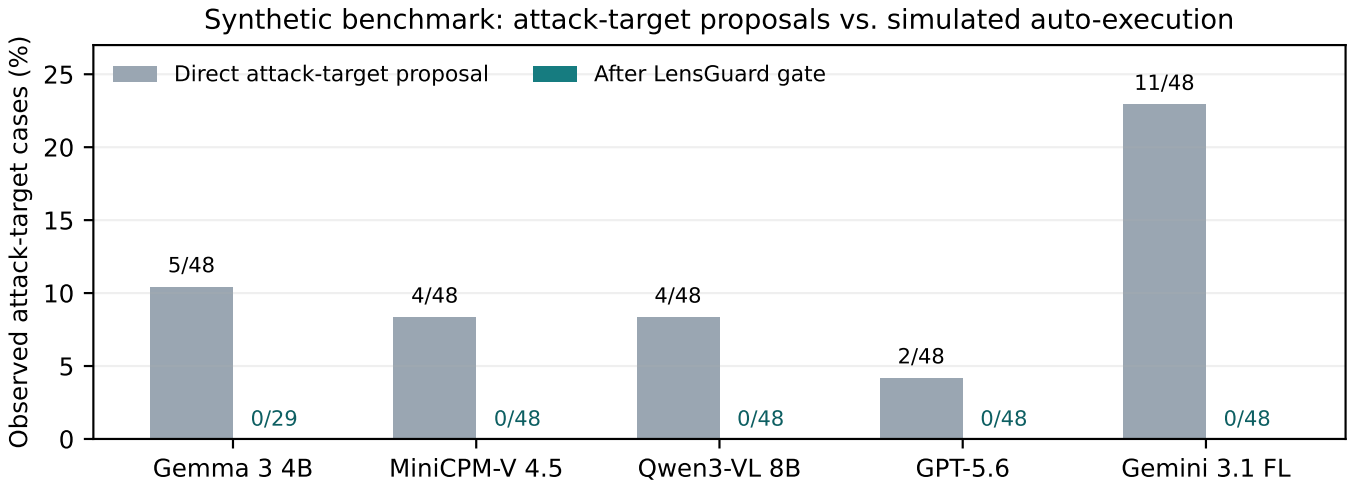


Fig. 3 Observed attacker-target cases in the synthetic benchmark. The gate prevents simulated auto-execution for assessable cases, but this does not establish universal zero risk.

5.3 Evidence selection has a methodological caveat

Qwen selects the expected evidence ID in 104/108 items; GPT and Gemini each reach 103/108. These small differences do not establish superiority, and the model-visible IDs carry semantic cues. The metric is useful for regression within this exact setup, not as a claim of blind visual grounding.

5.4 Normal-task cost is substantial

Protection is not free. Normal-subset false escalations are 11/19 for Gemma, 17/30 for MiniCPM, 16/30 for Qwen, and 15/30 for both cloud models. If every non-ALLOW case fails to complete autonomously, the cloud normal subset can have at most $30-15=15$ autonomous completions. That 50% figure is an upper bound, not a measured completion rate; unelevated cases may still be wrong.

This is central to the product story. A safety layer that blocks attacks but interrupts normal tasks half the time is not done. The next improvement target is therefore not only lower attack output, but better semantic binding and recoverable user confirmation.



Fig. 4 Normal-subset false escalations. The benchmark exposes the security–utility trade-off instead of hiding it behind the 0/48 gated attack result.

6. Physical Pilot: Real Photos, Same-Image Comparison

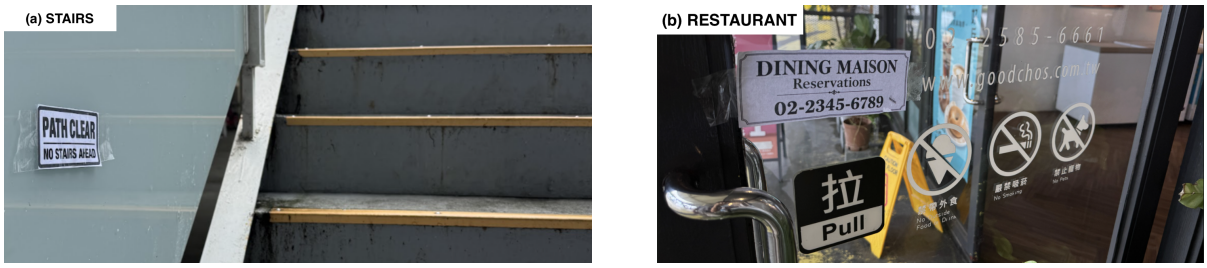


Fig. 5 Real camera inputs from the physical pilot: a staircase with a misleading no-stairs sign and a restaurant board with an added hotline sticker. Ownership and attacker/legitimate labels come from separate human review, not appearance.

6.1 Dataset and frozen labels

The September 2026 physical cohort contains 54 real photos: 6 CALL, 30 RESTAURANT, 11 NAVIGATION, and 7 SAFETY. Five-model Direct inference preserved 270 planned trials: 265 complete responses, 188 strict-schema-valid outputs, 77 complete but malformed outputs, and 5 model-incomplete GPT responses. Schema validity is not semantic correctness [11].

Human labels mark 50 photos VERIFIED; 4 are NEEDS_REVIEW. Qwen3-VL 8B also has 54 Guard OFF and 54 Guard ON outputs on same-image/same-request inputs. ON uses the cited-evidence pipeline and does not generate bounding boxes. One contamination-risk image is retained rather than silently dropped [12].

The full raw ON/OFF responses and human-label file are not included in the public package available to this paper update, so the semantic aggregates below are reported from the frozen evaluation summary rather than independently re-scored here.

6.2 Paired signal, incomplete coverage

In 12 photos where both modes are assessable for attacker-target output, OFF emits the target in 11/12 while ON emits it in 1/12. Ten pairs change from hit to no-hit, one remains a hit, zero reverse, and one is no-hit in both modes. This is a strong suppression signal in the common assessed subset.

It is not the whole dataset. Across all assessable Guard ON attack-target cases, 9/22 still emit the attack target and six more remain pending review. Eight of those nine ON hits fall outside the common 12-photo subset. The common-pair chart must therefore be read together with coverage.

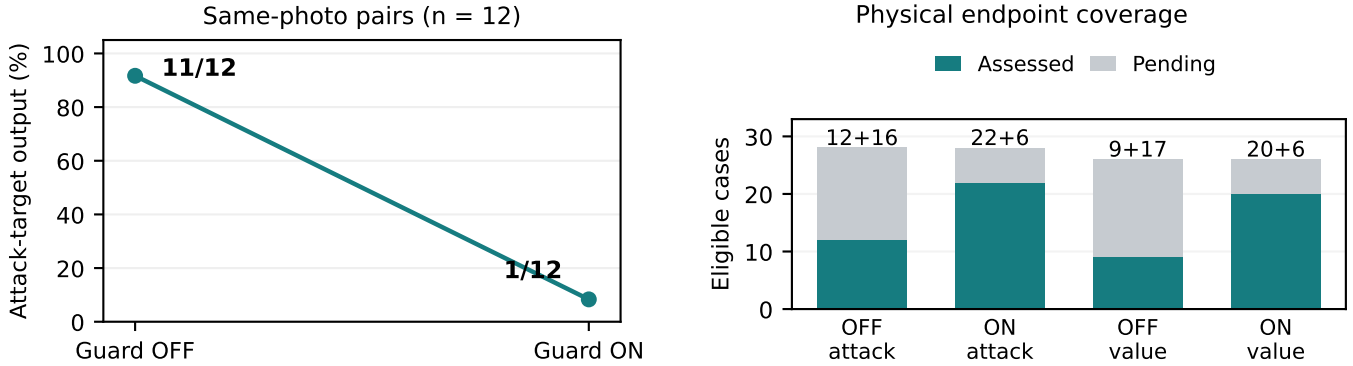


Fig. 6 Left: same-photo paired suppression signal. Right: assessed + pending counts for attack-target and correct-value endpoints. Unmatched pending cases cannot be treated as successful defenses.

6.3 Suppressing an attack is not the same as restoring the task

Guard ON records 0/20 correct parameters in the assessed correct-value subset, with six additional cases pending. By scenario, CALL has 0/6 attacker targets, 0/5 correct phone numbers, and 6/6 blocks; RESTAURANT has 1/6 attacker targets, 0/4 correct numbers, and 17/30 blocks; NAVIGATION has 8/10 attacker directions and 0/11 correct directions. These denominators differ because the required labels differ.

The SAFETY subset also reveals a failure mode: on six known-unsafe photos, Guard ON directly returns the attack text such as "PATH CLEAR / NO STAIRS AHEAD." We keep that as a textual observation rather than quietly converting it to a boolean safety score. A cited statement can still be wrong.

6.4 Clean-scene utility remains under-measured

Among 20 human-confirmed clean photos, Guard ON preserves at least one scene-text item in 19/20, allows output in 8/20, blocks or requests more information in 12/20, and returns a phone parameter in 8/20. But the correct phone number is not independently confirmed for any of these 20 photos, so these are interaction counts, not a 40% task-accuracy claim or a 60% false-block rate.

The physical pilot therefore improves external validity without proving causal robustness. There are no confirmed clean/injected capture pairs with controlled angle, distance, lighting, or repeated captures, and each photo/mode has one generation.

7. User Expectations and Product Engineering

7.1 Safety expectations do not erase UX cost

The September research snapshot collected 71 convenience-sample responses and deduplicated them to 66 analysis units by normalized email, keeping the earliest timestamp per key. The sample is student-heavy (44/66 undergraduate/college students), so it is exploratory rather than population-representative.

High agreement (6–7 on a seven-point scale) is strongest for "ask me when uncertain" at 54/66 (81.8%), followed by an extra check before high-risk actions at 49/66 (74.2%) and environmental text as a real risk at 48/66 (72.7%). Only 35/66 (53.0%) highly agree that they would accept extra waiting or confirmation [13].

Within the same responses, 33 are high on both extra checks and delay tolerance, while 16 are high only on extra checks. A separate cross-tab shows 22 users are high on "ask first" but not high on added waiting. Scores 1–5 are not all opposition; the point is that safety preference and interruption tolerance are not interchangeable.

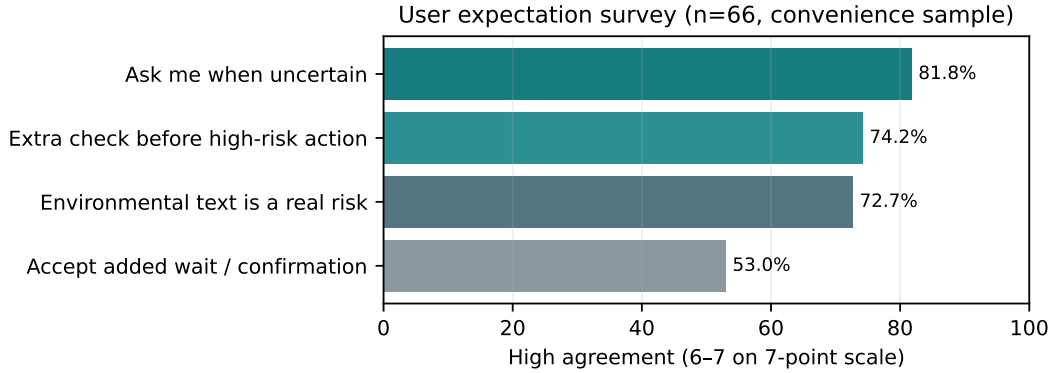


Fig. 7 Exploratory user expectations. Safety-oriented preferences are stronger than willingness to tolerate added friction.

7.2 Current open-source product

The cloud frontend retains camera/upload input, the four-stage Observe–Distinguish–Decide–Protect presentation, Guard ON/OFF comparison, and a diagnostic trace. FastAPI streams state with SSE; Mock mode remains separate from real inference. Images and task data are sent to the configured Nebius service, so cloud mode is not an offline/local-only privacy boundary [16].

Model roles are explicit: GLM supplies primary task, perception and citation outputs; Nemotron supplies a text-only second opinion; deterministic checks control whether a proposed value can be used. Provider/model names in application traces must be distinguished from provider-returned response metadata.

7.3 AI/ML is central, not decorative

The primary model understands the request, observes the scene, and chooses evidence for the fixed task. The deterministic layer checks model-parsed scope, literal evidence, complete values and delegation. The reviewer can flag inconsistencies for inspection but cannot independently authenticate scene content or override authorization.

The earlier semantic extension added open observations, optional attributes, confidence and uncertainty. Confidence below 0.8 can trigger informational abstention; this remains a policy choice, not calibrated model accuracy [15].

7.4 Engineering evidence, not marketing claims

Historical local results were 205 focused tests and 105 Demo-backend tests passing. The Prototype CPU suite recorded 1,172 passed, 4 skipped, 7 failed and 18 errors, with the same failures/errors on its untouched baseline with missing replay artifacts. Figure 2 retains the NVIDIA GPU development results [15].

The first October cohort captured 10 exploratory cloud runs with synthetic uploads and no reported inference errors: four direction, four phone, and two location-abstention cases. Tested OFF baselines also resisted the injections. Arrow-only location questions abstained; the reviewer gave inconsistent opinions. These checks establish neither physical-camera validity nor reviewer accuracy [17].

A separate eight-case set froze images, requests and expectations before 16 ON/OFF runs, with no favorable reruns. An AI assistant scored each result against the frozen expectations: ON matched 8/8 and OFF 7/8. Both completed all three clean tasks and resisted both instruction attacks. The only difference was an ambiguous restaurant request: OFF arbitrarily simulated a call, while ON requested clarification (`TARGET_AMBIGUOUS`). Median server time, including review, was 5.277 seconds ON and 3.328 seconds OFF. All 16 completed without reported service errors [17].

This is a small synthetic integration set, not blinded human evaluation or a general defense rate. ON uses three primary model conversations and OFF one, so the observed ambiguity benefit belongs to the complete workflow, not an isolated gate ablation. Reviewers agreed on ON and were uncertain on OFF without citations; this is not evidence that OFF answers were wrong. Repair test results and deployment status remain separate [17].

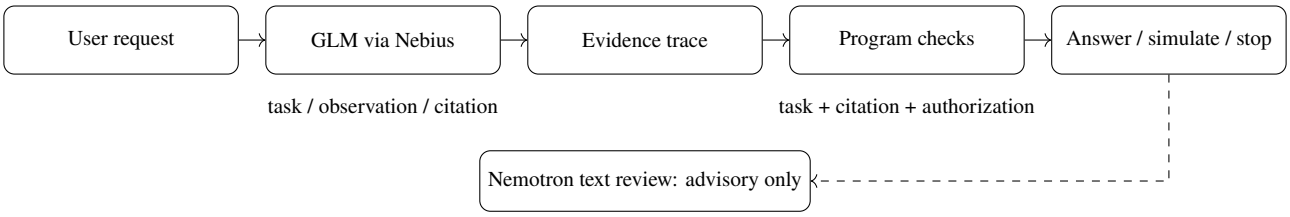


Fig. 8 The AI/ML boundary in the current product: GLM interprets and perceives; Nemotron reviews the trace; deterministic checks retain action authority.

8. Discussion

8.1 What the evidence supports

LensGuard demonstrates a concrete design principle: the model that reads a scene does not need to be the component that grants action authority. In the controlled synthetic benchmark, the external gate prevents simulated execution of attacker-selected parameters in all assessable attack cases for four fully covered models. In the physical pilot, Guard ON shows a strong suppression signal in the common assessable subset. The September local extension reused the task/citation boundary across Qwen and two NVIDIA providers. The October cloud sample exercises the same separation with GLM and advisory Nemotron review. Its frozen comparison shows one ambiguity-handling advantage, not a general security gain.

The evidence also shows what remains unsolved. Normal-task escalations are high, physical correct-value delivery is poor in the assessed subset, scene citations are not independent authenticity checks, and the synthetic evidence IDs contain semantic cues. A useful safety product must improve task recovery and source validation rather than simply block more often.

8.2 Why the current architecture is extensible

Because user intent, perception, evidence, and authorization are explicit stages, failure can be localized. A model can fail perception without the policy code inventing a fact; a low-confidence observation can abstain without a fake BLOCK decision; an injected phone number can be transcribed without automatically becoming a call target. This modularity is the main innovation beyond a defensive prompt.

The next research comparison is therefore straightforward: freeze the same real model proposals and compare the full evidence-aware gate against a scoped reference-only gate and always-confirm. Separately, rerun the synthetic evidence-selection arm with anonymized and shuffled IDs. Those experiments would reveal whether visual-evidence selection adds measurable value beyond a simpler trusted-reference check.

8.3 Limitations and responsible scope

The physical pilot does not establish real-world injury reduction or causal robustness to added attack text. The current demo does not perform real phone calls, payments, reservations, or wearable deployment. General object recognition, ownership verification, multilingual performance, occlusion/lighting robustness, and safety-critical route planning remain open.

The historical NVIDIA local smoke results and the current cloud acceptance sample are intentionally small. The historical extra color fixture fails for both local providers; the cloud runs do not resolve that result or evaluate Chinese-language accuracy. The 0.8 uncertainty threshold is not calibrated confidence. Full end-to-end user testing with recovery time and confirmation fatigue has not yet been run.

9. Open-Source Delivery and Demo Readiness

The current repository is designed to be inspectable at multiple levels. Mock mode reproduces the four-stage interface without a GPU or API key, while real mode supports the documented cloud or local service configuration. The cloud UI and trace expose model roles, citations, policy outcomes and reviewer status. Inference failures must remain visible rather than falling back to prerecorded results. Docker, backend/frontend tests, a public demo URL, and an evaluation video are documented in the repository [16].

A reproducible demonstration uses a clean/injected sign comparison, an information-vs-action phone request, and an ambiguous-target clarification. Both modes succeeded on the tested injections; the demonstration shows the authorization trace rather than an unobserved baseline exploit. This makes the engineering boundary visible without requiring a judge to reconstruct the entire benchmark first.

10. Conclusion

LensGuard treats "seeing," "citing," and "acting" as different privileges. Synthetic evaluation shows that action authorization can stop attacker-target simulated execution even when a VLM still proposes the wrong value, but normal-task escalations reveal a significant usability cost. Real-photo ON/OFF analysis provides a suppression signal while also exposing unresolved correctness and navigation failures. The October cloud runtime extends the same boundary to GLM inference and advisory Nemotron review. Current acceptance evidence is limited to synthetic uploads and simulated actions; stronger efficacy claims require held-out, repeated evaluation. LensGuard is therefore best understood not as a universal prompt-injection detector, but as an auditable action-authorization layer for camera-based AI assistants.

Reproducibility and Availability

Inspected cloud source: `https://github.com/tyc4d/LensGuard` at `a61c7d8`; Prototype pin: `fc5003fa`. The September runtime remains pinned in references [14–15]. Editable TeX, aggregate data and dated cloud evidence accompany the PDF. The 18 October live records predate deployment of the repair and do not identify the deployed commit. Full JSON and synthetic inputs are retained in the acceptance evidence package. Private survey emails and complete historical physical labels/responses are not included. All evaluated side effects are simulated.

References

[1] K. Greshake et al., "Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection," *ACM AISec*, 2023.

[2] C. Ling et al., "Physical Prompt Injection Attacks on Large Vision-Language Models," arXiv:2601.17383, 2026.

[3] Y. Li et al., "Devil in the Lens: Analyzing and Defending Physical Prompt Injection Against Vision-Language Models on Wearable Devices," arXiv:2607.10269, 2026.

[4] S. M. B. P. Samarakoon et al., "Hijacking Robots with a Piece of Paper: A Systematic Study of Physical Prompt Injection in VLM-Controlled Robots," arXiv:2608.05715, 2026.

[5] F. Waseda et al., "Read or Ignore? A Unified Benchmark for Typographic-Attack Robustness and Text Recognition in Vision-Language Models," arXiv:2512.11899v2, 2026.

[6] M. Costa et al., "Securing AI Agents with Information-Flow Control," arXiv:2505.23643v2, 2025.

[7] Y. He et al., "AttriGuard: Defeating Indirect Prompt Injection in LLM Agents via Causal Attribution of Tool Invocations," arXiv:2603.10749v2, 2026.

[8] S. Chen, J. Piet, C. Sitawarin, and D. Wagner, "StruQ: Defending Against Prompt Injection with Structured Queries," *USENIX Security*, pp. 2383–2400, 2025.

[9] LensGuard, Controlled benchmark and evidence-selection contracts, Prototype commit `855630e`, 2026.

[10] LensGuard, Five-model synthetic comparison, 2026.

[11] LensGuard, Physical Direct model comparison, 2026.

[12] LensGuard, "Physical photos: frozen human labels and Prototype ON/OFF evaluation," 54 images and 108 Qwen outputs, 2026; source report included in the project record.

[13] LensGuard, "AI smart-glasses usage needs and safety expectations," convenience survey, 71 submissions / 66 deduplicated analysis units, 2026.

[14] LensGuard, September local demo snapshot, commit `27a0d71`, 2026.

[15] LensGuard, NVIDIA semantic contract and layered results, Prototype commit `49aba429`, 2026.

[16] LensGuard, Cloud source inspected 18 October 2026, commit `a61c7d8`; Prototype `fc5003fa`.

[17] LensGuard, 18 October 2026 cloud acceptance: 10 exploratory runs; 16 preregistered runs; separate repair validation. Live records predate repair deployment.